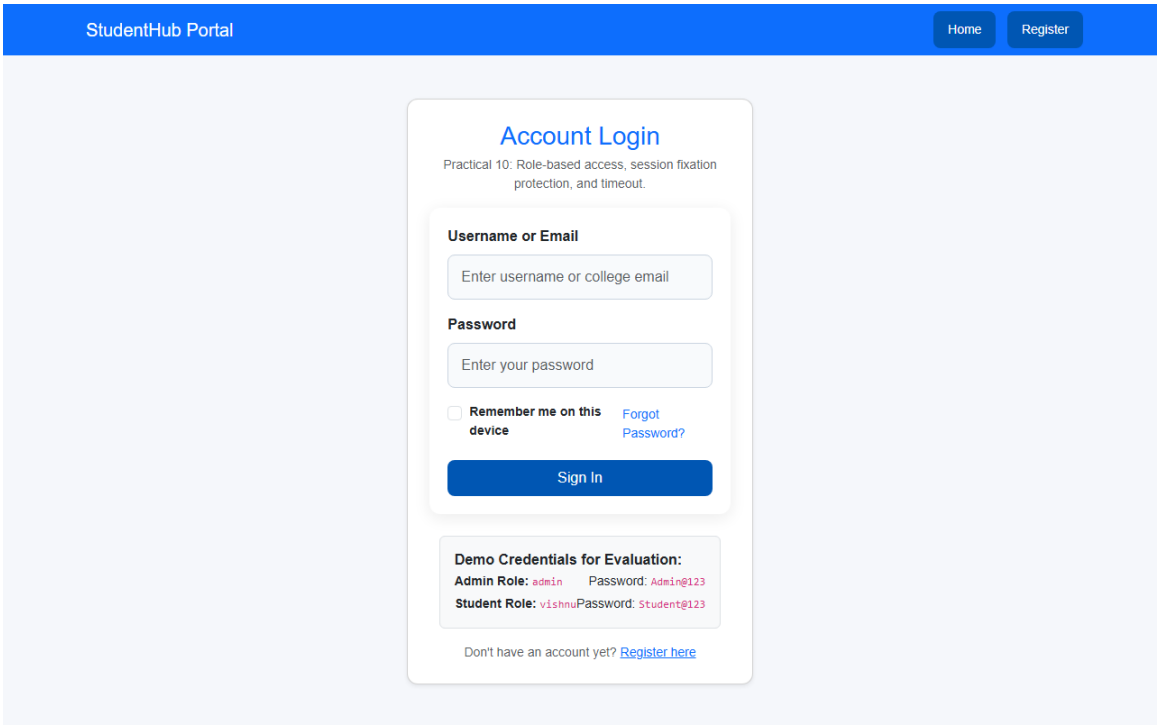
PRACTICAL – 10

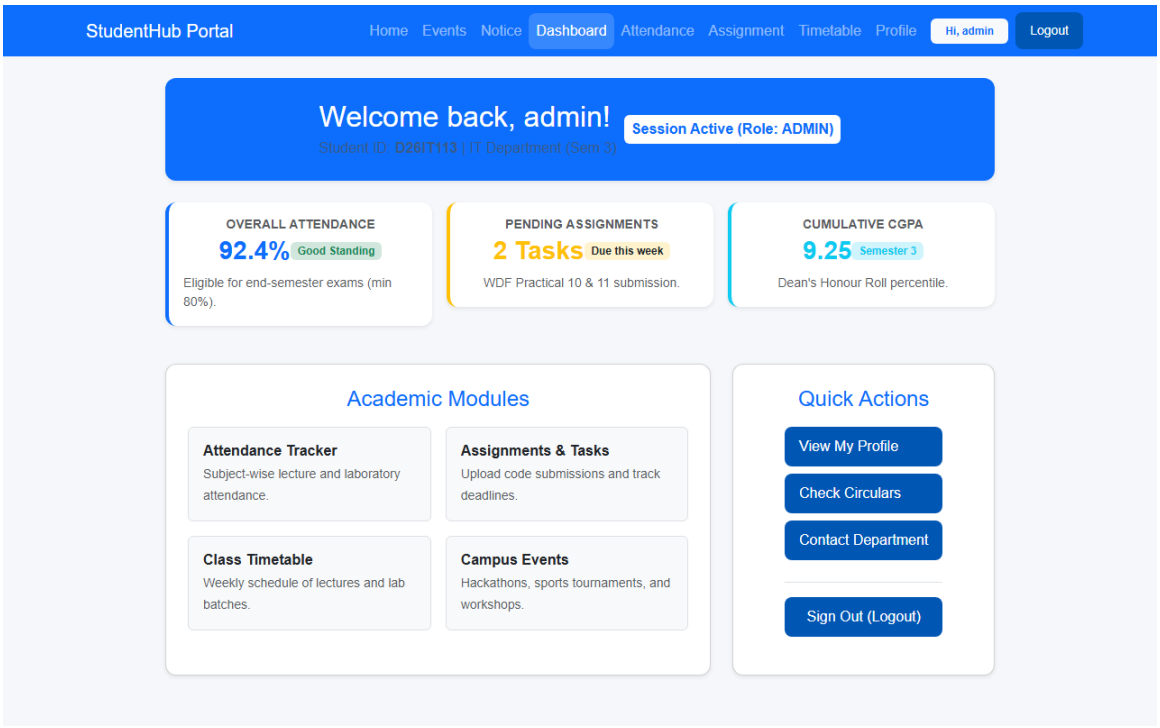
Problem Definition: Develop secure login and logout functionality using PHP sessions. Verify password using password_verify(), regenerate session ID after login, restrict dashboard access, implement role-based redirection, session timeout, and optional secure remember-me token.

Output:

Secure Login Page with Remember-Me Option:



Authenticated Student Dashboard with Active Session:



Question & Answer:

1. Are sessions started and destroyed securely?

Ans. Yes. Sessions are started securely using session_start(). Upon login, session_regenerate_id(true) is called to prevent Session Fixation attacks. On logout, session variables are cleared, session cookies are deleted, and session_destroy() terminates the session completely.

2. Is password_verify() used correctly?

Ans. Yes. During authentication, password_verify($password, $user['password_hash']) is used to securely verify the submitted password against the stored database hash in constant time, preventing timing-based attacks.

3. Is unauthorized dashboard access blocked?

Ans. Yes. Access to protected pages is restricted using the require_login() and require_role() middleware functions. Unauthenticated visitors are intercepted and redirected to login.php with appropriate informational messages.

4. Is session timeout implemented?

Ans. Yes. The session middleware checks the elapsed time since the user's last interaction ($_SESSION['last_activity']). If inactivity exceeds 900 seconds (15 minutes), the session is automatically destroyed and the user is redirected to the login page with a timeout notice.

5. Are admin and student users redirected to appropriate dashboards?

Ans. Yes. Based on the user's role stored in the database, administrators are redirected to admin_dashboard.php while students are routed to dashboard.php.

Conclusion / Learning Outcome:

In Practical 10, a complete session-based authentication system was developed. Key security concepts implemented include timing-safe credential verification with password_verify(), session fixation prevention via session_regenerate_id(true), role-based redirection, inactivity timeouts, and persistent authentication using hashed remember-me tokens.

Github link :- https://github.com/07vish/sh.git